

GESTIÓN DE CIBERSEGURIDAD : Uso no autorizado de recursos .-

Fase 1: Preparación

Objetivo: Evitar que ocurra o actuar rápido si ocurre.

Política de uso aceptable (AUP): Tener un documento firmado por alumnos, profesores y padres donde se prohíba explícitamente usar el correo institucional para promocionar esquemas piramidales, criptomonedas, marketing multinivel (MLM) o cualquier actividad con ánimo de lucro personal.

Filtrado: Configurar el servidor de correo (G Suite for Education, Microsoft 365, etc.) para bloquear palabras clave como "invierta", "gane dinero", "multinivel", "recluta", "oportunidad única".

Formación: Charlas a estudiantes sobre ciberseguridad y ética digital, explicando que el correo del colegio es solo para fines académicos.

Fase 2: Identificación

Objetivo: Detectar el abuso.

Alertas automáticas: El sistema de correo detecta un alto volumen de mensajes salientes desde una cuenta de alumno/a con contenido sospechoso (ej: "inversión garantizada").

Denuncia de otros usuarios: Profesores o compañeros reportan que han recibido correos de estafa piramidal desde una dirección @colegio.edu.

Análisis de logs: El administrador de TI revisa tráfico anómalo: 200 correos enviados en 10 minutos desde una misma cuenta de estudiante.

Fase 3: Contención

Objetivo: Parar el daño inmediato.

Suspender la cuenta de correo del alumno infractor (evitar que siga enviando más spam piramidal).

Cambiar contraseña de esa cuenta (por si fue hackeada o si el alumno la está usando intencionalmente).

Eliminar los correos ya enviados desde el buzón del alumno y de las bandejas de entrada de los destinatarios (si el sistema lo permite, ej: administrador de Exchange elimina mensajes en remoto).

Notificar internamente al departamento de orientación / dirección.

Fase 4: Mitigación

Objetivo: Reducir el impacto residual y prevenir propagación.

Escaneo de equipos: Revisar el ordenador del alumno (portátil del centro o BYOD) en busca de malware, keyloggers o cuentas comprometidas.

Revisar otros servicios: Verificar si el alumno usó su cuenta para campañas similares en redes sociales usando el logo del colegio.

Bloqueo preventivo: Si fue un ataque masivo, bloquear temporalmente el envío de correos a grupos completos (ej: a todos los de 3º ESO) durante horas punta.

Fase 5: Recuperación

Objetivo: Volver a la normalidad de forma segura.

Reactivar la cuenta solo después de:

- Cambiar contraseña y activar 2FA (obligatorio a partir de ahora para ese usuario).
- Entrevista con el alumno y firma de nuevo compromiso.
- Eliminar cualquier contacto o lista de distribución creada para el fraude.
- Restaurar filtrando: Asegurarse de que los filtros anti-spam estén reforzados.

Informar a la comunidad educativa (sin señalar al alumno directamente): "Se han detectado intentos de estafa piramidal usando cuentas del centro. No haga clic en enlaces de inversión milagrosa".

Fase 6: Actuaciones post-incidente

Objetivo: Aprender, sancionar si toca y mejorar.

Análisis de causas: ¿Fue el alumno víctima de una estafa previa que le reclutó? ¿O actuó por iniciativa propia con ánimo de lucro?

Medidas disciplinarias (según normativa del centro):

Leve: suspensión de cuenta 1 semana y trabajo ético.

Grave (con lucro demostrado): pérdida de derecho a usar ordenadores del centro, comunicación a padres y, si hubo daño económico a terceros, derivación a autoridades (LOPDGDD, fiscales de menores).

Mejora técnica:

Implementar rate limiting (máximo 30 correos/hora por cuenta de alumno).

Deshabilitar reenvío automático a cuentas externas.

Actualizar el plan de ciberincidentes añadiendo este caso concreto a la base de conocimiento.

Charla obligatoria para el grupo-aula sobre "Fraudes piramidales y MLM en entornos digitales".